

FINAL TEST

Introduction to cyber security

31/01/2024

Exercise 1 : QUIZ ISO 27001 + AWARENESS + OWASP – 15 points (Only 1 possible answer)

1. What is the primary role of an information security policy according to ISO 27001 ?

- A. Define penalties for non-compliance.
- B. Provide direction and support for information security.
- C. Detail all security procedures.
- D. List all assets and their corresponding security measures.

2. Which of the following best describes the purpose of an Information Security Risk Assessment in ISO 27001 ?

- A. To ensure compliance with legal requirements.
- B. To identify, analyze, and evaluate information security risks.
- C. To allocate budget for information security.
- D. To train employees on information security.

3. What is a key principle of the OWASP Top 10 in application security?

- A. Prioritizing network security over application security.
- B. Emphasizing the importance of secure coding practices.
- C. Focusing solely on software encryption.
- D. Avoiding open source software due to security vulnerabilities.

4. Which ISO 27001 clause requires the organization to evaluate the performance and effectiveness of the ISMS?

- A. Leadership
- B. Performance evaluation
- C. Operation
- D. Planning

5. In ISO 27001, which of the following is a mandatory document?

- A. Risk Treatment Plan
- B. Information Security Policy
- C. Incident Management Procedure
- D. Business Continuity Plan

6. OWASP recommendations primarily aim to prevent:

- A. Data theft
- B. Application-level security breaches
- C. Network intrusions
- D. Physical security breaches

7. Regarding ISO 27001, the term 'context of the organization' refers to:

- A. The legal and regulatory requirements the organization must comply with.
- B. The internal and external issues that affect the organization's ability to achieve the intended outcomes of its ISMS.
- C. The technological environment of the organization.
- D. The scope of the ISMS within the organization.

8. Which of the following best describes 'asset management' in the context of ISO 27001?

- A. Managing the financial assets of the company.
- B. Identifying, classifying, and protecting information assets.
- C. Only managing IT hardware and software.
- D. Managing human resources and personnel.

9. In ISO 27001, which is an essential step in the risk management process?

- A. Purchasing insurance for cyber risks.
- B. Implementing general controls for all risks.
- C. Assessing the likelihood and impact of identified risks.
- D. Avoiding all high-risk activities and processes.

10. Under the OWASP guidelines, 'Injection Flaws' typically occur when:

- A. An attacker is able to inject a virus into the company's network.
- B. Untrusted data is sent to an interpreter as part of a command or query.
- C. Users inject additional funds into the security budget.
- D. Security patches are injected into existing software.

11. What does the 'A' in the CIA triad of information security stand for?

- A. Authentication
- B. Authorization
- C. Availability
- D. Assessment

12. What is the purpose of 'access control' in ISO 27001?

- A. To ensure only authorized personnel can access physical locations.
- B. To prevent unauthorized access to information systems and data.
- C. To control access to the internet and external websites.
- D. To monitor employee attendance and timekeeping.

13. In the context of ISO 27001, 'continuous improvement' refers to:

- A. Regularly increasing the IT security budget.
- B. Constantly adding new security technologies.
- C. The ongoing process of enhancing the ISMS.
- D. Increasing the frequency of security audits.

14. According to the OWASP Top 10, 'Sensitive Data Exposure' occurs when:

- A. An organization publicly shares its annual financial report.
- B. Confidential data is not adequately protected, leading to unauthorized access.
- C. Employees discuss sensitive information in public areas.
- D. A company's website is offline due to maintenance.

15. What does 'incident management' in ISO 27001 involve?

- A. Managing IT system downtimes.
- B. Handling events that could potentially compromise information security.
- C. Documenting and reporting physical security breaches.
- D. Tracking customer complaints and feedback.

Exercise 2 : open questions – 10 points

- 1. Describe the role of top management in the implementation and maintenance of an ISMS according to ISO 27001.**

- 2. Explain the importance of an Information Security Risk Treatment Plan in ISO 27001. How should an organization approach creating this plan?**

- 3. How do the OWASP Top 10 guidelines contribute to web application security, and how can organizations effectively implement these guidelines?**

- 4. In the context of ISO 27001, how does an organization determine the scope of its ISMS, and why is this an important step?**

- 5. What are the challenges in maintaining compliance with ISO 27001, and how can organizations address these challenges?**

Exercise 3 Risk management – 10 points

CyberSecure Inc., a company specializing in cybersecurity solutions, is planning to launch a new cloud-based security service for businesses. The service will provide real-time threat detection and response capabilities. The project involves sensitive data handling and complex system integrations.

Before proceeding, the board of directors wants a thorough security risk analysis focusing on data protection and system integrity. The business process under scrutiny is the development and deployment of the cloud service.

The technical resources involved are:

- Multiple cloud servers hosted by third-party providers.
- Internal databases storing client information and threat data.
- Remote access for employees to the company's systems.
- Use of open-source software in some parts of the development.

The company has a basic security policy in place but has not updated it to reflect the specifics of cloud computing and remote work.

A- Methodically Identify 5 Intolerable Risks

B- Place these Risks in a Risk Level Matrix and Explain Your Choices

C- Propose Organizational and Human Measures to Reduce these Risks

Exercise 4 GDPR - 15 points

FitCity, led by Ms. Bonnesanté, is a company based in Berry, France, offering sports activities to businesses and individuals. It organizes Fitness events in Bourges, Châteauroux, and other cities in the Berry region. To run these events, FitCity employs 10 sports coaches.

Until recently, the company primarily offered in-person classes at local businesses, mainly during lunch breaks. However, the Covid-19 crisis abruptly halted these in-person activities. This situation significantly impacted the financial health of the company, posing a risk to job sustainability.

Therefore, Ms. Bonnesanté decided to offer her services online. Google Meet was chosen as the video conferencing tool. The classes were offered to subscribers who had a FitCity membership card and also to new clients upon registration. Advertising for these new services quickly spread on Instagram. Payments for the services were made through online payment platforms.

Additionally, the sports coaches began using a questionnaire to better understand the personal characteristics of new clients. This questionnaire collects health data to tailor classes to clients' age and physical abilities.

However, the director is concerned about FitCity's compliance. The sports industry is subject to strict regulations, and these new activities generate new GDPR (General Data Protection Regulation) constraints. She thus seeks your expertise as a GDPR consultant.

- 1. How would you present GDPR to Ms. Bonnesanté? (2 points)**
- 2. Is FitCity affected by the GDPR? Justify your answer. (2 points)**
- 3. What are your initial recommendations for her organization? (4 points)**
- 4. What are her data processing activities that need to be analyzed? (2 points)**

Ms. Bonnesanté wants to expand her business by offering online health & well-being conferences. Remote conferences are indeed a good way to expand the business beyond the region and to avoid room rental costs. She chooses a digital marketing company, Digital Park, to help launch this activity quickly. Digital Park uses various digital marketing techniques to target potential customers, such as collecting data via online forms, cookies, trackers, etc. However, this agency does not have a clear privacy policy.

- 5. What are the priority measures to be taken to comply with the prospecting of new clients? (2 points)**
- 6. Define a possible data breach for the recruitment part. What procedure should be put in place in case of a data breach? (3 points)**